Universidad de Occidente, sede central

Facultad de Ingeniería




# Operación Trazabilidad: informe de auditoría de sistemas

Anthony Samuel Ordoñez Son · 2401002033

María José Aldana Culajay · 2301002013

Luis Antonio Vicente Zapón · 2301002003

Auditoría de Sistemas

Ing. Herman Ávila

[Fecha de entrega pendiente de confirmar]

## Informe parcial del equipo: integración pendiente

Este borrador incorpora el análisis del incidente. Las secciones de planeación, riesgos, terceros y continuidad siguen pendientes; no constituye el informe final de 12–18 páginas solicitado por el curso.

## Resumen ejecutivo

Responsable: Luis Antonio Vicente Zapón. [Completar: Decisiones, riesgos prioritarios y límites, máximo una página. ]

## Alcance y metodología

Responsable: María José Aldana Culajay. [Completar: Encargo, período acordado, exclusiones, criterios e independencia. ]

## Arquitectura, riesgos y controles

Responsable: María José Aldana Culajay. [Completar: Diagramas y matrices, con referencias a sus anexos. ]

## Reconstrucción del incidente

El análisis del incidente está incorporado al anexo siguiente. Revisión del estudiante pendiente.

## Hipótesis y análisis forense

El análisis del incidente está incorporado al anexo siguiente. Revisión del estudiante pendiente.

## Respuesta y continuidad

Las propuestas de investigación se incorporan al anexo. Faltan análisis de impacto al negocio, tiempo objetivo de recuperación, pérdida tolerable de datos y revisión de continuidad.

## Terceros, privacidad e inteligencia artificial

Responsable: Luis Antonio Vicente Zapón. [Completar: Criterios y fuentes verificados por el responsable. ]

## Hallazgos y plan de acción

Responsable: Luis Antonio Vicente Zapón, con aportes del equipo. [Completar: Hallazgos consolidados, acciones, responsables, plazos y comprobación. ]

## Referencias y anexos

Responsable: María José Aldana Culajay integra. [Completar: Citas y referencias según la séptima edición del estilo de la Asociación Estadounidense de Psicología; evidencias, consultas y registro de uso de inteligencia artificial trazables. ]

## Anexo: investigación del incidente

Aporte de Anthony Samuel Ordoñez Son. La integración y la revisión de los otros responsables siguen pendientes.

## Reconstrucción y evaluación del incidente de RedNova

**Responsable:** Anthony Samuel Ordoñez Son, carné 2401002033. **Límite temporal del análisis:** 15 de octubre de 2026, a las 23:59:59, hora de Guatemala (UTC−6). Preparación asistida por Codex; revisión del estudiante pendiente.

## Qué se examinó y qué permite concluir

El caso académico describe la pérdida de acceso al sistema de gestión comercial y de clientes (CRM) de RedNova el 14 de octubre de 2026. También reporta archivos aparentemente cifrados y una nota de extorsión. Estos indicios justifican investigar un posible ataque de ransomware: un programa malicioso que bloquea archivos y exige un pago. Todavía no permiten identificar al responsable, establecer la causa del incidente ni confirmar una exfiltración, es decir, una extracción de información sin autorización.

Se trabajó con dos tipos de material. Primero, el documento del curso, que resume los sucesos y las declaraciones de la empresa. Segundo, una base de datos ficticia creada para probar consultas y métodos de análisis. Los resultados del laboratorio demuestran que las pruebas funcionan sobre esos datos; no comprueban que los sucesos ocurrieran así en RedNova. No se recibieron registros originales de sus sistemas.

Las afirmaciones de Tecnología, Desarrollo, Seguridad, el proveedor y el administrador de la base de datos deben contrastarse. Por ahora no puede sostenerse que toda la responsabilidad sea del proveedor, que la transferencia haya sido una fuga ni que los datos hayan quedado intactos. La comparación de órdenes con facturas y respaldos sigue pendiente.

Las referencias oficiales de evidencia se conservan para localizar el material. Por ejemplo, «alerta crítica de seguridad (E-07)» significa la entrada de alertas del expediente del curso, no un registro original obtenido de la empresa. Los seis papeles de trabajo adjuntos explican objetivos, procedimientos, resultados y límites de cada análisis.

## Secuencia reportada y límites de las horas

La cronología adjunta reproduce los trece eventos de la página 4 del caso. Las horas corresponden a la referencia de Guatemala indicada por el docente. No se han verificado los relojes de los sistemas; por eso los campos de hora original y de corrección comprobada permanecen vacíos.

El 12 de octubre, a las 16:15, el proveedor solicitó renovar un acceso privilegiado a una interfaz de integración entre sistemas (API). La autorización figuraba pendiente. El 14 de octubre, a las 02:17, se reportó una sesión remota de la cuenta denominada ext_ops_04, sin autenticación multifactor: una verificación adicional a la contraseña. Ese nombre identifica una cuenta, no a una persona. No

se sabe quién la utilizó ni si era compartida. Los demás eventos no identifican cuentas responsables.

A las 02:26 se reportó un aumento de permisos; a las 02:31, una lectura de 31,840 registros de clientes; a las 02:35, una transferencia externa de aproximadamente 1.6 gigabytes (GB); y a las 02:42, cambios en 216 órdenes comerciales. A las 03:02 se instaló una nueva versión del servicio de integración. A las 03:18 se emitió una alerta crítica y a las 03:42 el sistema comercial dejó de estar disponible.

Tabla 1. Intervalos calculados a partir de las horas reportadas.

| Desde / hasta | Tiempo transcurrido | Qué permite decir |
|---|---|---|
| Inicio de sesión 02:17 / alerta 03:18 | 61 minutos | Es la separación entre dos marcas; no demuestra cuándo empezó la intrusión ni cuánto tardó en detectarse. |
| Alerta 03:18 / caída 03:42 | 24 minutos | No prueba que nadie atendiera la alerta ni que se borraran registros. |
| Caída 03:42 / solicitud de recuperación 04:05 | 23 minutos | Se reportó una solicitud; no se conoce el inicio efectivo de la restauración. |
| Caída / acceso de solo consulta 08:57 | 315 minutos: 5 h 15 min | Describe el retorno parcial reportado. |
| Caída / operaciones de escritura 09:37 | 355 minutos: 5 h 55 min | Incluye 40 minutos de acceso de solo consulta. |
| Caída / solicitud de conciliación 11:15 | 453 minutos: 7 h 33 min | Pedir comparar órdenes y facturas no acredita que la comparación haya terminado. |

Entre la solicitud de acceso del proveedor y la sesión remota transcurrieron 34 h 02 min. La cercanía de los sucesos posteriores justifica investigarlos juntos, pero falta una sesión, transacción o proceso que los conecte. Tampoco se ha demostrado que aquella solicitud fuera autorizada o utilizada por la misma persona.

Un reloj adelantado o atrasado puede cambiar la interpretación. Como ejercicio hipotético, si los relojes de la lectura y la transferencia tuvieran errores independientes de hasta cinco minutos, los cuatro minutos reportados podrían representar desde seis minutos en orden inverso hasta catorce en el orden indicado. Esto ilustra el problema; no estima el error real. Si dos marcas proceden del mismo reloj y mantienen el mismo desfase, la diferencia se conserva. Compartir el nombre de un sistema no demuestra que usen el mismo reloj. Los escenarios completos están en el papel de trabajo sobre integridad y horarios (PT-25).

## Explicaciones alternativas que siguen abiertas

Se consideran tres explicaciones. Ninguna tiene evidencia suficiente para aceptarse como causa demostrada.

**Robo de credenciales.** Una persona no autorizada pudo obtener la contraseña de la cuenta remota y utilizarla para leer datos, transferirlos y afectar el sistema. La sesión sin verificación adicional es compatible con esta posibilidad. Sin embargo, no existe una conexión técnica demostrada entre esa sesión, la lectura de clientes y la salida de información. Para sostenerla se necesitan registros coincidentes de sesión, equipo, proceso y archivos enviados. Una transferencia autorizada o trazas que asignen los eventos a procesos independientes debilitarían esa cadena específica.

**Uso indebido de un acceso legítimo.** Una persona que tenía acceso a la cuenta pudo exceder sus autorizaciones. Las advertencias previas sobre cuentas justifican investigar esta opción, pero se desconoce quién disponía de la contraseña y qué podía hacer. Se requieren la asignación histórica de la cuenta, el dispositivo utilizado, las autorizaciones y las acciones realizadas. Probar que se usó una cuenta no demuestra por sí solo quién actuó ni con qué intención. Un compromiso documentado ajeno al titular debilitaría esa atribución.

**Actividad autorizada coincidente con un ataque por otra vía.** La lectura, el envío o la instalación de software pudieron tener una finalidad legítima mientras la afectación comenzaba por otro mecanismo. Desarrollo alega aprobación verbal y el destino del envío no está clasificado; ninguno de esos datos acredita autorización. Hacen falta la tarea programada, los archivos, el destino y la aprobación correspondientes, además de evidencia de la otra vía de ataque. Un contenido no autorizado vinculado técnicamente al ataque refutaría la legitimidad de esa actividad.

Según las horas reportadas, los cambios de órdenes ocurrieron antes de instalar la nueva versión. Esto debilita la explicación de que esa instalación, por sí sola, causó los cambios anteriores. No permite descartarla definitivamente sin verificar los relojes. El mapa causal adjunto identifica los enlaces por investigar; las pruebas de permisos del laboratorio no constituyen enlaces probatorios sobre RedNova.

## Qué significan las cifras de clientes y transferencia

Se calculó cuánto ocuparían siete campos comerciales de 31,840 clientes ficticios: identificador, nombre, departamento, plan, fecha de alta, estado y clasificación. Se seleccionaron los primeros identificadores de la base de laboratorio, sin asumir que fueran los registros leídos en la empresa.

Una exportación como tabla de texto con valores separados por comas (CSV) ocupa **2,058,909 bytes**, unos 2.06 megabytes decimales. Una exportación que repite los nombres de los campos en cada registro (JSON Lines) ocupa **5,115,483 bytes**, unos 5.12 megabytes. Se usó codificación UTF-8, que permite representar caracteres como las tildes. El procedimiento, los campos y las huellas digitales de los archivos calculados se documentan en el papel de transferencia (PT-22).

Los aproximadamente 1.6 GB reportados son unas **777.11 veces** el primer tamaño y **312.78 veces** el segundo. Si todo el envío contuviera exactamente una copia de las 31,840 filas, cada una tendría

que ocupar aproximadamente **50,251 bytes**. Es una comparación de magnitudes, no una reconstrucción del envío. Faltan el diseño real de la base, los archivos adjuntos, posibles repeticiones, la compresión y el contenido exacto.

El anexo técnico también explora la unidad binaria gibibyte (GiB), distinta del gigabyte decimal, y otros tamaños hipotéticos de fila. El caso dice GB, por lo que no se cambia su unidad. Un envío único de los siete campos ficticios no explica ese volumen; la diferencia tampoco descarta que salieran datos de clientes junto con otros archivos. Para confirmar una extracción no autorizada se necesitan contenido, dueño del destino, equipo y proceso de origen, autorización y registros de red. Los cuatro minutos entre lectura y transferencia no indican la duración del envío y no permiten calcular su velocidad.

## Qué se sabe de las 216 órdenes

El caso reporta 216 órdenes modificadas, sin precisar campos, montos ni responsables. La consulta de laboratorio reproduce 216 cambios en 216 órdenes distintas. Para construir el ejercicio se supusieron 144 cambios de monto y 72 de estado, todos a las 02:42. Esos detalles fueron inventados para probar el método; no proceden de los sistemas de RedNova.

Se compararon las 216 filas con el historial ficticio. En todas se conservan como desconocidos el usuario, la sesión y la vía del cambio. Otra consulta encontró diez pares candidatos a duplicidad: veinte órdenes distintas de las 216 anteriores. La semejanza no demuestra doble cobro. Sin facturas, pagos y autorizaciones no corresponde sumar montos ficticios, atribuir fraude ni calcular una pérdida económica.

Para evaluar la integridad se requiere el historial original antes y después de cada cambio, un respaldo validado y la conciliación con el sistema de facturación y finanzas (ERP). También deben vincularse persona, sesión y transacción. El papel de trabajo sobre órdenes y respaldos (PT-23) detalla esa revisión.

## Respuesta al incidente y recuperación recomendada

No se recibieron registros que permitan determinar quién atendió la alerta crítica, qué hizo primero o cuándo la cerró. Tampoco constan el aislamiento de equipos, la revocación de accesos, la preservación de memoria o discos, el respaldo utilizado ni la autorización para volver a escribir. La vuelta del servicio no demuestra que se eliminara la amenaza ni que los datos se recuperaran completos.

La prueba de respaldos contiene una reducción ficticia de 8.2 a 3.2 GiB y una programación sin ejecución registrada. Su restauración del 1 de julio también es un dato simulado: en este trabajo no se restauró un respaldo real. El caso solo afirma que la última restauración documentada ocurrió varios meses antes.

Las dos observaciones propuestas siguen **no concluyentes**: falta acreditar el seguimiento de la alerta y la protección de los registros de actividad. La primera investiga responsabilidades y seguimiento; la segunda, permisos, conservación y copias protegidas. No son hallazgos definitivos

ni causas raíz probadas. Se utilizan como buenas prácticas las recomendaciones del Instituto Nacional de Estándares y Tecnología de Estados Unidos (NIST), con versión y páginas en las fuentes adjuntas. No se ha demostrado que RedNova las adoptara como obligación interna o contractual.

Se proponen once acciones para las primeras 72 horas desde la futura activación del plan. La administración debe dirigir la respuesta y registrar las decisiones. Se recomienda aislar de forma selectiva los activos en riesgo y revocar accesos comprometidos, coordinando la captura de información que podría perderse. Ante daño activo, una medida urgente no debe esperar una recopilación perfecta: debe documentarse qué se conserva, qué se pierde y quién decide.

Después se recomienda preservar copias con acceso restringido y una huella digital SHA-256, un valor que permite detectar cambios posteriores en el archivo. Esa huella no acredita que el contenido original fuera verdadero. La recuperación debería hacerse en infraestructura limpia. Antes de habilitar escritura se deben validar el respaldo, la ausencia de señales de compromiso, la integridad de los datos y la conciliación de órdenes. Son propuestas del auditor; no acciones realizadas en la empresa.

## Información pendiente para cerrar la evaluación

Luis Antonio Vicente Zapón, responsable de continuidad y consolidación de hallazgos, debe aportar el análisis de impacto al negocio y los objetivos aprobados de recuperación: tiempo máximo para restablecer el servicio (RTO) y pérdida temporal de datos tolerable (RPO). Sin ellos, los 315 y 355 minutos no permiten evaluar cumplimiento. Tampoco bastan para juzgar un acuerdo contractual de nivel de servicio (SLA).

María José Aldana Culajay, responsable de planeación, riesgos y controles, debe aportar políticas y la evaluación de controles. Sus productos y los de continuidad no se han recibido completos en las ubicaciones revisadas. Quedan pendientes la revisión del estudiante, la revisión cruzada y la integración del informe del equipo. Las comprobaciones del laboratorio y los cálculos delimitan qué preguntar; registros originales con identidades, contenido y relojes verificados podrían cambiar las conclusiones.